

ISO/IEC 27001:2022

Readiness and Gap Assessment

CloudNova Analytics Pvt. Ltd.

Fictional GRC Case Study

disclaimer

This fictional project was independently developed to demonstrate practical skills in ISO/IEC 27001 readiness assessment, ISMS evaluation, information-security risk management, control assessment, internal audit planning and remediation. CloudNova Analytics Pvt. Ltd. is not a real organization. This document is not an official certification audit or certificate.

Prepared by	Shreejal
role	GRC Analyst / Information Security Analyst
Assessment date	15 June 2026
Report version	1.0
Classification	Public document

-ready edition for GitHub, LinkedIn and job applications

Contents

1. Executive Summary
2. Organization Profile
3. Assessment Objective and Scope
4. Assessment Methodology
5. Readiness Dashboard
6. Clause-Level Gap Assessment
7. Detailed Findings Register
8. Information Security Risk Register
9. Statement of Applicability Summary
10. Risk Treatment Plan
11. Ninety-Day Remediation Roadmap
12. Internal Audit Workpaper
13. Management Conclusion
14. Limitations and Notes
- Appendix A. Risk Scoring Method
- Appendix B. Evidence Index

1. Executive Summary

CloudNova Analytics Pvt. Ltd. was assessed against the requirements and relevant control areas of ISO/IEC 27001:2022 to determine its readiness for an external certification audit. The assessment was based on a fictional evidence package covering governance, risk management, access control, supplier security, secure development, vulnerability management, incident response, backup and recovery, business continuity, privacy, internal audit and management review.

The organization has implemented several useful technical controls, including multi-factor authentication, database encryption, daily backups, vulnerability scanning, pull-request reviews and endpoint protection. However, those controls are not supported by a sufficiently mature Information Security Management System.

Overall conclusion

CloudNova is not currently ready for an ISO/IEC 27001 certification audit. Major readiness barriers include incomplete risk treatment, an outdated Statement of Applicability, ineffective offboarding, weak supplier assurance, inadequate incident and continuity testing, a non-independent internal audit and the absence of a formal management review.

Metric	Assessment
Overall maturity	Developing
Certification recommendation	Postpone certification
Recommended remediation period	90-180 days
Highest-priority domains	Risk treatment, IAM, supplier assurance, audit, continuity
Evidence confidence	Moderate - fictional evidence package only

Key strengths

- Multi-factor authentication is used for AWS and Google Workspace.
- Production databases and backups are encrypted.
- Daily database backups are performed.
- Pull-request reviews, automated tests and static-code scanning are present.
- Infrastructure vulnerability scans are performed monthly.
- Employee confidentiality agreements are in place.

Key readiness barriers

- No formal Risk Treatment Plan, residual-risk record or management risk acceptance.
- The Statement of Applicability is outdated and contains unsupported exclusions.
- Former employees and contractors retained access after termination.
- Supplier-risk assessments and assurance-report reviews are not performed.
- Incident, restoration and business-continuity processes are not adequately tested.
- Internal audit independence and management-review requirements are not met.

2. Organization Profile

Item	Details
Company	CloudNova Analytics Pvt. Ltd.
Industry	Cloud-based business intelligence and analytics
Location	Kathmandu, Nepal
Employees	68
Customers	Financial institutions, retail companies and healthcare providers
Primary hosting	Amazon Web Services
Key SaaS providers	GitHub, Google Workspace, Slack, Jira and HelpFlow
Sensitive information	Customer records, financial summaries, employee information, API credentials, logs and backups

Technology and information environment

- Cloud-hosted analytics platform with production and staging environments.
- Remote and office-based employees with access to corporate and production systems.
- Customer-support staff can access and export customer information.
- Software development is performed internally using GitHub and agile practices.
- Operational dependencies include cloud, authentication, collaboration, support and payment providers.

3. Assessment Objective and Scope

The objective was to evaluate whether CloudNova has established and implemented the governance, risk-management, operational and monitoring practices required to support an effective ISMS and to identify the corrective actions needed before certification.

Assessment objectives

- Identify gaps against ISO/IEC 27001:2022 management-system requirements.
- Evaluate the design and implementation of relevant security controls.
- Assess the adequacy of the risk assessment and Statement of Applicability.
- Prioritize risks and corrective actions.
- Determine whether the organization is ready to proceed to certification.

In-scope environment

- Cloud analytics platform and customer-facing services.
- AWS production and staging environments.
- Software-development and deployment operations.
- Customer-support and HR information.
- Corporate IT systems, Kathmandu office and remote workers.

Proposed exclusions requiring stronger justification

- Building security managed by the landlord.
- Customer-controlled devices.
- Third-party ISP infrastructure.
- Unauthorized personal devices.

Scope observation

Rented premises do not automatically make physical-security controls irrelevant. CloudNova remains responsible for the security of its own workspace, access cards, visitors, network equipment and information-processing areas.

4. Assessment Methodology

This project used a structured readiness-assessment method. It is not an official scoring model and should not be interpreted as an audit opinion.

Step	Method
1	Review the fictional company context, ISMS scope and interested parties.
2	Review simulated policies, risk records, control descriptions and operational evidence.
3	Assess management-system requirements and relevant control areas.
4	Record findings, evidence, risk impact, severity and likely root cause.
5	Assign corrective actions, accountable owners and target dates.

Step	Method
6	Assess readiness and prepare a prioritized remediation roadmap.

Finding severity scale

Severity	Definition
Critical	Immediate and substantial threat to sensitive information, legal obligations or essential operations.
High	Significant control failure requiring priority remediation before certification.
Medium	Important weakness that reduces ISMS effectiveness or evidence quality.
Low	Limited-risk weakness or documentation improvement.
Observation	No confirmed failure, but process improvement is advisable.

5. Readiness Dashboard

Assessment domain	Status	score
Context and scope	Partially established	55%
Leadership and governance	Developing	45%
Risk assessment and treatment	Weak	30%
Operational controls	Partially implemented	55%
Performance evaluation	Inadequate	20%
Continual improvement	Developing	35%

Scoring note

The percentages are a transparent presentation method, not an official ISO compliance score. Final certification decisions belong to an independent certification body.

Finding distribution

Severity	Count	Examples
Critical	1	Sensitive-data exposure through uncontrolled access/export pathways
High	12	Risk treatment, offboarding, supplier assurance, incident response, backup testing, audit
Medium	6	Scope, roles, awareness records, metrics and documentation controls
Low/Observation	3	Process formalization and evidence-quality improvements

6. Clause-Level Gap Assessment

Clause area	Status	Primary gap	Severity
Context of the organization	Partial	Interested-party requirements and exclusion justifications are incomplete.	Medium
Leadership	Partial	Security responsibilities are informal and not fully assigned.	Medium
Planning	Nonconforming	Risk treatment, residual risk and acceptance are not formally managed.	High
Support	Partial	Awareness, competence and documented-information evidence are insufficient.	Medium
Operation	Nonconforming	Risk treatment and operational-control processes are inconsistently implemented.	High
Performance evaluation	Nonconforming	Independent internal audit and formal management review are absent.	High
Improvement	Partial	Corrective actions lack root-cause analysis and effectiveness verification.	High

7. Detailed Findings Register

ID	Finding	Severity	Evidence summary	Recommended action	Owner	Target
GOV-01	Incomplete ISMS scope justification	Medium	Some exclusions are not formally justified, particularly physical security.	Document scope boundaries, interfaces, dependencies and reasons for exclusions.	CTO	30 days
GOV-02	Interested-party requirements not documented	Medium	Interested parties are listed, but their legal, contractual and security requirements are not recorded.	Create an interested-party and compliance-obligations register.	Compliance Lead	30 days

ID	Finding	Severity	Evidence summary	Recommended action	Owner	Target
GOV-03	Security responsibilities are informal	Medium	Roles are distributed but not approved in job descriptions or a RACI matrix.	Approve an ISMS responsibility matrix and update relevant job descriptions.	CEO / CTO	30 days
RSK-01	Risk assessment is incomplete	High	Several risks lack owners, existing controls, residual scores and acceptance decisions.	Update the methodology and risk register; assign owners and acceptance criteria.	CTO	30 days
RSK-02	No formal Risk Treatment Plan	High	Treatments have no formal owners, deadlines, budgets or approval.	Create and approve a Risk Treatment Plan linked to risks and controls.	CTO	30 days
SOA-01	Statement of Applicability is outdated and unsupported	High	The SoA is not approved, contains weak exclusions and is not linked to risk evidence.	Reassess applicability, document evidence and obtain management approval.	CTO / Compliance	30 days
AST-01	Information asset inventory is incomplete	High	Databases, source repositories, SaaS systems, keys, backups and owners are missing.	Create a comprehensive information-asset register with owners and classification.	IT Manager	45 days
IAM-01	Delayed offboarding	High	Former staff remained active in Slack and GitHub after termination.	Integrate HR and IT offboarding; verify disablement within 24 hours.	HR + IT	7 days
IAM-02	Shared privileged account and weak privileged review	High	Two engineers share an emergency AWS account and privileged access is not separately reviewed.	Use individual privileged identities, controlled break-glass access and quarterly reviews.	DevOps Lead	15 days
IAM-03	No periodic access review	High	User and service-account access is not formally recertified.	Implement quarterly access certification and service-account credential rotation.	IT Manager	30 days
SUP-01	Supplier-risk management is inadequate	High	Criticality, due diligence, assurance review, monitoring and exit planning are absent.	Establish supplier classification, due diligence and annual review processes.	Procurement / CTO	60 days
DEV-01	Secure-development governance is incomplete	High	No approved secure-development policy; production data and secrets are mishandled.	Approve secure SDLC requirements, prohibit unmanaged production data in testing and enable secret scanning.	Engineering Lead	45 days
VUL-01	Vulnerability remediation is ineffective	High	Critical and high findings exceeded expected timelines without approved exceptions.	Approve remediation SLAs, escalation and risk-acceptance procedures.	DevOps Lead	30 days
LOG-01	Logging and monitoring are insufficient	High	Thirty-day retention, deletable logs and missing export/login alerts reduce detection capability.	Approve retention, protect logs and implement risk-based monitoring alerts.	Security Engineer	60 days
IR-01	Incident process is incomplete and not followed	High	No severity model, evidence process or lessons learned; phishing event was not formally recorded.	Update the response plan, train responders and conduct an exercise.	CTO / Security	45 days
BCM-01	Recovery and continuity are not adequately tested	High	RTO/RPO are undefined; restoration evidence and continuity exercises are absent.	Complete BIA, define objectives, test restore and conduct a continuity exercise.	DevOps + Operations	60 days
PRV-01	Data-retention commitments were violated	Critical	Former customer data remained for over nine months despite a 30-day commitment.	Implement deletion workflow, monitoring and evidence of completion.	Data Owner / Legal	15 days
AUD-01	Internal audit lacks independence and coverage	High	The DevOps Lead audited his own controls and the audit scope was narrow.	Create an audit programme and appoint an independent competent auditor.	Executive Management	60 days
MGR-01	No formal ISMS management review	High	Security discussions do not cover the required structured inputs and outputs.	Conduct and document a formal management review after internal audit.	CEO / CTO	75 days
CAP-01	Corrective-action process is incomplete	Medium	Jira tickets lack root cause, deadlines, ownership and effectiveness verification.	Standardize corrective-action records and closure checks.	Compliance Lead	45 days

8. Information Security Risk Register

Risk	Asset	Scenario	Existing controls	Inherent	Treatment	Residual	Owner
R-01	Customer database	Unauthorized access due to delayed offboarding and absent reviews	MFA, individual accounts	Critical	Automated offboarding and quarterly access certification	Medium	IT Manager
R-02	Customer exports	Data leakage through broad support access and weak monitoring	Manager approval	Critical	Restrict export, require approval, encrypt and monitor downloads	Medium	Support Manager
R-03	Cloud platform	Regional outage causes prolonged unavailability	Daily backups	High	Cross-region backups, DR runbook and annual exercise	Medium	DevOps Lead
R-04	Source code and secrets	API key exposure through Git history	Private repositories, code review	High	Secret scanning, credential rotation and response procedure	Low	Engineering Lead
R-05	Endpoints	Loss or compromise of unencrypted laptops	Antivirus on endpoints	High	Full-disk encryption and device-compliance enforcement	Low	IT Manager
R-06	Suppliers	Critical vendor failure or control weakness	Contract review	High	Risk-tiering, assurance review, monitoring and exit plan	Medium	Procurement
R-07	Incident response	Delayed containment and notification	Basic 2023 response document	High	Approved severity model, legal escalation and exercises	Medium	CTO
R-08	Customer retention	Failure to delete terminated-customer data	Contractual commitment only	Critical	Automated deletion, exception alerts and completion evidence	Low	Data Owner
R-09	Backups	Restore failure during disruption	Encrypted daily backups	High	Quarterly restore tests and cross-region copies	Medium	DevOps Lead
R-10	Compliance	Certification failure due to weak audit and management review	Informal monthly meetings	High	Independent internal audit and formal management review	Low	Executive Management

9. Statement of Applicability Summary

The complete Statement of Applicability should be maintained as an editable spreadsheet. The table below provides a management-level summary.

Control area	Applicable	Status	Evidence / gap
Access management	Yes	Partially implemented	MFA exists; access reviews and timely offboarding are absent.
Supplier security	Yes	Partially implemented	Contracts exist; due diligence and assurance review are absent.
Secure development	Yes	Partially implemented	PR reviews and scanning exist; secrets and test-data controls are weak.
Incident management	Yes	Partially implemented	A plan exists but lacks key procedures and was not followed.
Physical security	Yes	Partially implemented	Key cards exist; visitor, room and environmental controls are weak.
Backup and recovery	Yes	Partially implemented	Daily encrypted backups exist; restore testing evidence is absent.
Logging and monitoring	Yes	Partially implemented	Logs exist but retention, protection and alert coverage are inadequate.
Data masking	Yes	Not implemented	Sensitive financial and healthcare-related information may be processed.

SoA assessment

The original exclusion of physical security because the office is rented is not supportable. Data masking also requires reconsideration because the service may process financial and healthcare-related information.

10. Risk Treatment Plan

Action	Corrective action	Related finding	Priority	Owner	Target	Required evidence
RTP-01	Remove stale accounts and review all privileged access	IAM-01, IAM-02	Critical	IT Manager	7 days	Access review report and disablement timestamps
RTP-02	Delete overdue former-customer data and validate all terminated accounts	PRV-01	Critical	Data Owner	15 days	Deletion logs and customer-level evidence
RTP-03	Approve risk methodology, register and treatment plan	RSK-01, RSK-02	High	CTO	30 days	Signed methodology and treatment plan
RTP-04	Update and approve the Statement of Applicability	SOA-01	High	CTO / Compliance	30 days	Approved SoA with evidence links
RTP-05	Perform documented backup-restoration test	BCM-01	High	DevOps Lead	30 days	Restore report showing RTO/RPO results
RTP-06	Implement supplier due diligence and annual reviews	SUP-01	High	Procurement	60 days	Vendor register, reviews and action plans
RTP-07	Update and test incident-response procedures	IR-01	High	Security Lead	45 days	Approved plan and tabletop report
RTP-08	Conduct independent internal audit	AUD-01	High	Executive Management	60 days	Audit programme, workpapers and report
RTP-09	Conduct formal management review	MGR-01	High	CEO / CTO	75 days	Approved minutes and decisions
RTP-10	Verify closure effectiveness for major findings	CAP-01	High	Compliance Lead	90 days	Effectiveness-test records

11. Ninety-Day Remediation Roadmap

Days 1-30: Immediate risk reduction

- Remove stale accounts and review all privileged access.
- Rotate potentially exposed credentials and formalize emergency access.
- Delete overdue former-customer data and validate retention obligations.
- Approve the risk methodology, updated risk register and Risk Treatment Plan.
- Correct and approve the Statement of Applicability.
- Perform a documented backup-restoration test.

Days 31-60: Process implementation

- Implement periodic access reviews and service-account credential rotation.
- Conduct supplier-risk assessments and review vendor assurance reports.
- Approve secure-development, cryptography, classification and retention procedures.
- Update the incident-response plan and conduct a tabletop exercise.
- Complete a business-impact analysis and define RTO/RPO.
- Deliver and record security-awareness training.

Days 61-90: Assurance and governance

- Conduct a business-continuity or disaster-recovery exercise.
- Complete an independent internal audit.
- Resolve major nonconformities and verify corrective-action effectiveness.
- Conduct a formal ISMS management review.
- Decide whether evidence supports entering Stage 1 certification activity.

12. Internal Audit Workpaper

Audit field	Workpaper entry
Audit objective	Determine whether access for terminated employees and contractors is removed within the approved timeframe.

Audit field	Workpaper entry
Scope	Slack, GitHub, AWS, Google Workspace and relevant VPN or support systems.
Population	All employees and contractors terminated during the audit period.
Sampling method	Risk-based sample including privileged, engineering and support accounts.
Evidence	HR termination records, access logs, disablement timestamps, tickets and manager approvals.
Test procedure	Compare effective termination time with account-disablement time and inspect for post-termination activity.
Observed result	Four former employees remained active in Slack for 8-19 days; one contractor retained GitHub access for 32 days.
Conclusion	The offboarding control is not operating effectively.
Recommended action	Integrate HR and IT workflows, require 24-hour completion and retain independent verification evidence.

Suggested audit evidence request list

- Complete employee and contractor termination population.
- System access exports for all in-scope platforms.
- Offboarding tickets and approval records.
- Privileged-access and break-glass usage logs.
- Exception and risk-acceptance records.
- Evidence that overdue access was removed and reviewed.

13. Management Conclusion

Certification-readiness conclusion

CloudNova has implemented several important technical security measures, but the evidence does not demonstrate a complete and effective Information Security Management System. The organization should not proceed directly to a certification audit. Management should complete the remediation programme, operate the improved controls for a sufficient period, retain objective evidence, complete an independent internal audit and conduct a formal management review before engaging a certification body.

Decision criteria before certification

- All critical findings are closed and effectiveness is verified.
- High-risk findings have been remediated or formally accepted by authorized management.
- The risk assessment, treatment plan and SoA are current and approved.
- Internal audit covers the full ISMS and is performed independently.
- Management review is documented and produces clear decisions.
- Recovery, incident and continuity exercises demonstrate acceptable results.
- Objective evidence exists for sustained control operation.

14. Limitations and Notes

- CloudNova Analytics Pvt. Ltd. is fictional.
- The evidence package and assessment records are simulated.
- No live interviews, system access, configuration review or technical testing occurred.
- Clause and control mappings are intended for demonstration.
- The report does not provide legal advice, certification or independent assurance.
- An actual engagement would require complete records, sampling, interviews and technical validation.
- The ISO name or logo should not be used in a way that implies endorsement or certification.

Recommended GitHub publication package

File	Purpose
README.md	Explains the project, methodology, disclaimer and key skills demonstrated.
Shreejal_ISO27001_GRC_Project.pdf	Primary polished report for recruiters and LinkedIn.
Shreejal_ISO27001_GRC_Project.docx	Editable source version.
fictional-company-case.md	Original CloudNova evidence package.
gap-assessment.xlsx	Clause-level assessment and findings.
risk-register.xlsx	Inherent and residual risk analysis.
statement-of-applicability.xlsx	Control applicability, status, justification and evidence.
risk-treatment-plan.xlsx	Remediation actions, owners, deadlines and evidence.

Appendix A. Risk Scoring Method

Risk is assessed using a five-point likelihood scale and a five-point impact scale. The inherent score is calculated before additional treatment; residual risk is assessed after proposed treatment.

Score	Likelihood	Impact
1	Rare	Negligible
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost certain	Severe / catastrophic

Risk score	Rating	Treatment expectation
1-4	Low	Monitor and improve where practical.
5-9	Medium	Assign owner and planned treatment.
10-16	High	Priority treatment and management oversight.
17-25	Critical	Immediate action and executive escalation.

Appendix B. Evidence Index

Evidence ID	Evidence description	Related area
E-01	Information Security Policy dated 5 January 2024	Leadership / policy
E-02	Risk register dated February 2025	Risk assessment
E-03	Statement of Applicability dated March 2025	Risk treatment / SoA
E-04	Device and hardware inventory spreadsheet	Asset management
E-05	Slack and GitHub termination-access observations	Identity and access
E-06	Supplier contracts and downloaded assurance reports	Supplier security
E-07	Secure-development workflow and Git history observation	Secure development
E-08	Vulnerability scan and remediation observations	Vulnerability management
E-09	Logging configuration and retention description	Logging and monitoring
E-10	2023 incident-response document and phishing event	Incident management
E-11	Backup configuration and August 2024 restore statement	Backup and recovery
E-12	April 2025 internal-audit report	Internal audit
E-13	Monthly technology meeting minutes	Management review
E-14	Jira corrective-action tickets	Corrective action

END OF REPORT